

Basic server-side template injection (code context)

Topic: SSTI | Difficulty: Practitioner

Description

The application uses the Python Tornado template engine and embeds a user-controlled value (preferred blog post author name) directly within a template expression context. By escaping the expression and injecting template directives, an attacker can execute arbitrary Python code on the server.

Steps to Exploit

1. Log in and navigate to account settings.
2. Locate the 'preferred name' / blog post author display setting.
3. Intercept the POST request in Burp Suite.
4. Set blog-post-author-display to: `{{%import os%}}{{os.system('whoami')}`
5. Forward the request and navigate to a blog post.
6. Observe command output rendered in the author display area.

Proof of Concept

Payload:

```
{{%import os%}}{{os.system('whoami')}
```

Effect:

```
Python os.system() executed server-side; output rendered in blog post author field.
```

Impact

- Remote Code Execution via Python os module.
- Full server takeover with web server process privileges.
- Access to environment variables, secrets, and application config.
- Potential for data exfiltration and establishing persistent access.

Mitigation / Remediation

1. Never interpolate user-controlled values into template expression contexts.
2. Use Tornado's autoescape feature and pass data via template context variables.
3. Sanitize and validate user input before storing or rendering it.
4. Monitor application logs for unexpected OS-level command execution.

CVSS Score

CVSS v3.1: 8.8 (High)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

CVSS Justification

- Attack Vector: Network - exploitable remotely.
- Attack Complexity: Low - requires knowledge of template syntax.

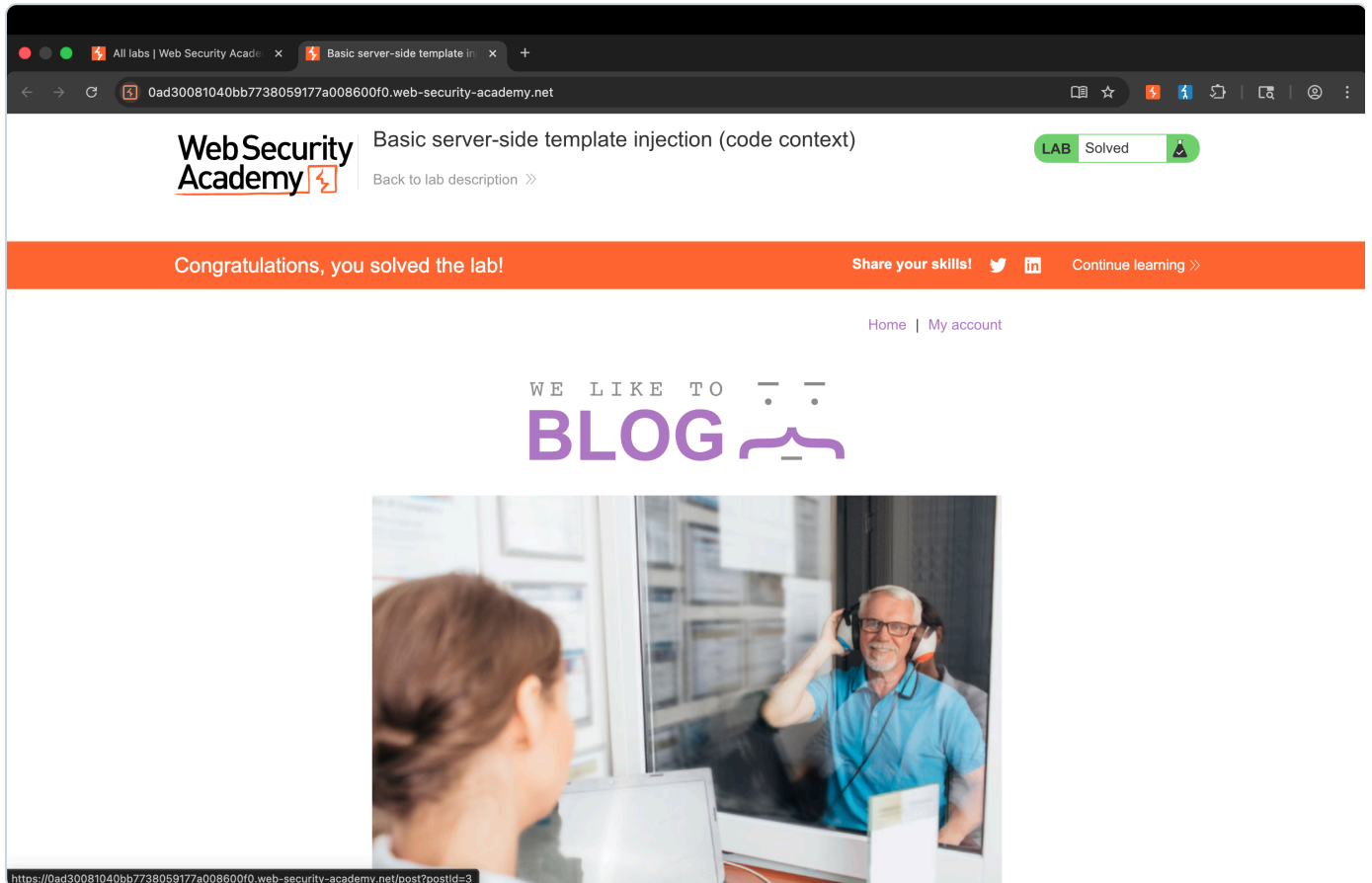
- Privileges Required: Low - requires authenticated session.
- User Interaction: None.
- Confidentiality / Integrity / Availability: High - full RCE achieved.

SSTI Code Context Tornado

Proof of Concept — Exploitation Evidence

Payload / exploit steps are documented in the **Proof of Concept** section of this writeup (above). Screenshot evidence of successful exploitation is shown below.

Lab Solved Confirmation



PortSwigger lab status changed to "Solved" after exploitation.